

Endpoint Credential Exposure on Shared University Computing Resources at North South University: A Technical Assessment and Zero-Cost Architectural Remediation Proposal

Sajid

*Department of Computer Science and Engineering
North South University, Dhaka, Bangladesh*

Document type: Technical proposal and research prospectus — Status: Draft v1.0 for internal review by NSU IT administration and prospective faculty supervisor

ABSTRACT

Universities have invested substantially in defending the email inbox — phishing-aware mail gateways, multi-factor authentication, security awareness training — while leaving a parallel attack surface almost entirely unaddressed: the shared endpoint. On a typical university laboratory computer, the default behaviour of the Chrome and Edge browsers permits one user's saved credentials, synchronised personal data, and authenticated session state to remain accessible to subsequent users of the same machine, without phishing, without malware, and without unauthorised privilege escalation. This proposal characterises this attack surface as it presently exists at North South University (NSU), Dhaka, identifies the specific technical mechanisms by which inter-session credential exposure occurs, and proposes an architectural remediation that uses only software already licensed to the university (Microsoft Windows 10/11, Microsoft Defender) or available at zero cost (Chrome Enterprise policies via Chrome Browser Cloud Management, Sysmon, Wazuh). A measurement and intervention study design is described, with the intent of producing both an operational improvement to NSU's security posture and a peer-reviewed publication. The proposal requests a one-laboratory, thirty-day pilot deployment with the cooperation of the NSU Information Technology Office.

Index Terms — *endpoint security, shared computing, browser security, credential theft, Chrome Enterprise, Windows Shared PC mode, infostealer malware, university cybersecurity, Bangladesh.*

1. INTRODUCTION

1.1 Context

In the academic year 2025–2026, the dominant narrative in cybersecurity literature and practitioner reporting has been the rise of credential-theft-driven breaches. The Verizon 2025 Data Breach Investigations Report identifies the human element in approximately sixty percent of breaches and stolen credentials as the leading initial access vector [1]. The 2024 compromise of Snowflake customer environments — leading to data theft at Ticketmaster, AT&T, Santander, Advance Auto Parts and other organisations — was traced by Mandiant to credentials harvested by infostealer malware as early as November 2020, with seventy-nine point seven percent of compromised accounts having prior credential exposure in stealer logs [2]. The same infostealer ecosystem — dominated in 2024 by Lumma, RedLine, RisePro, Vidar, Raccoon, Stealc, and MetaStealer — produced an estimated 330 million stolen credential records from 4.3 million infected machines in 2024 alone [3].

The defensive response in the literature and in industry practice has concentrated on two areas: (a) hardening the corporate email inbox against phishing-delivered initial access, and (b) measuring and improving end-user resistance to phishing through simulated phishing programs grounded in instruments such as the NIST Phish Scale [4]. The most rigorous studies of such programs have, however, reached pessimistic conclusions. Lain et al. [5], in a fifteen-month field study of 14,733 employees, found no statistically significant effect of embedded training on subsequent phishing susceptibility; the recent large-scale reproduction by Rozema and Davis [6] ($N = 12,511$) confirmed the null effect with negligible effect sizes. Where training does produce measurable reductions in click rates, the reductions decay rapidly and require continuous reinforcement to sustain [7].

This pessimism with respect to user-training interventions implies that the most defensible position for an under-resourced institution is to reduce the *opportunity* for user error by architectural means, rather than to attempt to eliminate user error through training. The present proposal applies this principle to a class of attack surface that has received little attention either in the academic literature or in university IT practice: the shared endpoint.

1.2 The shared-endpoint problem

A shared university endpoint — a laboratory computer, a library workstation, a faculty common-room desktop — is by design used by many people in sequence. Each user authenticates to one or more services (institutional email, learning management systems, third-party academic resources, personal accounts) during their session and is expected to terminate that authentication before leaving. The threat model implicitly assumed by most institutional IT operations is that this user-driven session termination is reliable and that any residual exposure between sessions is acceptable.

This assumption is incorrect under the default configuration of contemporary web browsers. The Chrome and Edge browsers, when used in their default state, encourage users to sign into a personal Google or Microsoft account in order to enable cross-device synchronisation of bookmarks, saved passwords, autofill data, browsing history, open tabs, and installed extensions. Once synchronisation is enabled, the local browser profile on the shared endpoint contains a downloaded copy of the user's complete personal browsing state, stored on disk in an encrypted database whose decryption key is bound to the

Windows user account under which the browser was running [8], [9]. Sign-out from the Google or Microsoft account does not, in itself, delete this local cache. When the Windows user account on the shared endpoint is itself shared between many students — as is common in university computer laboratories using a single *student* or *lab* account — the decryption key for the prior user's data is by definition available to the next user.

The remainder of this document characterises this attack surface in technical detail (Section 2), proposes a zero-cost architectural remediation (Section 3), describes a measurement and intervention study design that would both validate the remediation and produce a peer-reviewable contribution (Section 4), discusses limitations and ethical considerations (Section 5), and concludes with a specific request to NSU administration (Section 6).

1.3 Local context: NSU and Bangladesh

NSU operates Google Workspace for Education for staff and student email under the *@northsouth.edu* domain, with approximately twenty-five thousand active accounts (precise figure to be confirmed with the IT Office during the audit phase). The 2022 disclosure by the BRAC University “White-Hat Hacker community” of unauthorised access to the NSU registrar's email account [10] established that the institution is within the threat envelope of even informal adversaries. The Bangladeshi regulatory environment changed materially during 2025: the Cyber Security Ordinance 2025 was gazetted on 21 May 2025 [11], and the Personal Data Protection Ordinance 2025 was promulgated on 6 November 2025 [12], establishing for the first time a comprehensive data-protection regime in Bangladesh with extra-territorial scope, breach-notification obligations, and material penalties. Universities holding personal data of students, staff, and applicants are within scope. An attack of the form described in this proposal — one student walking away with the credentials of another — would constitute a reportable data breach under the PDPO 2025 with attendant legal and reputational consequences.

2. THREAT MODEL AND ATTACK SURFACE CHARACTERISATION

This section formalises the inter-session credential exposure problem on shared university endpoints. The threat model assumes an adversary who is a legitimate user of the university (a student or staff member with a valid *@northsouth.edu* account and physical access to laboratory and library computers during normal operating hours), who possesses standard-user privileges on those endpoints, and whose technical capabilities range from “no special skill” to “the capabilities of an undergraduate computer science student.” The model excludes nation-state adversaries, insider attacks by IT administrators, and physical attacks involving the disassembly of computer hardware.

Six attack classes are identified, ordered by the technical sophistication required.

2.1 Class A — Profile persistence after session termination

When a user signs into Chrome with a Google account on a shared endpoint and subsequently signs out, the local profile directory at *%LOCALAPPDATA%\Google\Chrome\User Data* is not deleted. The Login Data SQLite database, containing all credentials saved during the session, persists on disk. A subsequent user of the same Windows account can open Chrome, observe the prior user's profile in the avatar selector, navigate to *chrome://settings/passwords*, and view each saved credential after entering the Windows user account password. The Windows password challenge — implemented through the DPAPI subsystem — is not a defence in this scenario, because the next user is operating under the same Windows account and therefore knows or has access to the same password. Credentials can be exported to a CSV file from the same interface in two clicks. This attack requires no tools and approximately thirty seconds.

2.2 Class B — Synchronised data leakage

When a user enables Chrome Sync, the browser downloads to local storage a copy of all synchronised data types associated with the user's Google account: saved passwords, autofill profiles, payment methods, browsing history, open tabs from other devices, saved Wi-Fi credentials (on Android-linked devices), installed extension lists, and theme preferences. The data is encrypted in transit and at rest, but the decryption key on the local device is bound to the Windows user context [8]. A user who enables sync on a shared laboratory endpoint, even briefly, causes the entire synchronised state of their personal browsing life — including credentials and personal data from devices the user has never operated within NSU — to be cached on disk on the laboratory endpoint, where it remains subject to Class A exposure until the local profile is deleted.

2.3 Class C — Offline extraction of the credential database

The Chrome Login Data SQLite database can be read by any process operating under the same Windows user context as the original Chrome instance, without administrative privileges. Several free, publicly available, well-documented tools automate this extraction:

- **ChromePass** (NirSoft), a single signed Windows executable approximately 150 kilobytes in size, reads Login Data, decrypts each entry via the DPAPI *CryptUnprotectData* Win32 call, and exports the resulting plaintext credentials to CSV [13]. No installation is required.
- **LaZagne** [14], an open-source Python and compiled binary tool, performs the equivalent extraction across all major browsers (Chrome, Edge, Firefox, Opera, Brave) and across other local credential stores.
- **HackBrowserData** [15], a Go-based tool, performs equivalent extraction and includes support for bypassing the Application-Bound Encryption introduced in Chrome version 127 (July 2024) [16].
- The **Mimikatz** *dpapi::chrome* module, well-known in the offensive-security community, performs the same operation with additional capabilities.

The Application-Bound Encryption mechanism introduced by Google in July 2024 ties the decryption key for cookies to the Chrome process identity, rendering simple DPAPI-based cookie extraction from other processes ineffective. However, the mechanism applies primarily to cookies; saved passwords remain protected only by the per-user DPAPI master key. Further, Elastic Security Labs documented active bypass implementations for Application-Bound Encryption in production infostealer families (METASTEALER, XENOSTEALER) within weeks of the Chrome 127 release [16]. The Class C attack on saved passwords remains operational in 2026.

2.4 Class D — Malicious browser extensions

A second category of attack relies not on access to the local credential database but on the installation of a browser extension capable of reading every keystroke, form submission, and page content during the user's session, including in incognito mode. Three properties of the contemporary browser extension ecosystem make this attack class material:

- Extensions with the `<all_urls>` content-script permission have read access to every page DOM and can intercept form data prior to encryption. Manifest V3, the current Chrome extension specification, restricts certain network APIs but does not restrict content-script access [17].
- Extensions are subject to silent updates. The Cyberhaven supply-chain attack of 24 December 2024 [18], in which a phishing email to a single extension developer permitted the publication of a malicious update reaching approximately four hundred thousand users, was one of more than twenty extensions compromised through the same vector in the December 2024 wave [19]. Subsequent campaigns through 2025 and early 2026 have demonstrated continued compromise via developer phishing, account compromise, and the purchase or transfer of extension ownership from legitimate developers to malicious operators [20].
- Estimates by independent researchers place the cumulative user exposure to such malicious extensions in 2024–2025 at over three point two million users, with several compromised extensions retaining “Featured” status in the Chrome Web Store at the time of their malicious updates.

A student who has installed a benign-appearing extension on their personal device — a colour picker, a screenshot tool, a tab manager — may, without any further action, be exposed to credential capture if that extension is subsequently compromised.

2.5 Class E — Native covert keyloggers on shared endpoints

A user-mode keylogger can be implemented in fewer than thirty lines of Python using the `pynput` or `keyboard` library, executed via the windowless `pythonw.exe` interpreter, and made persistent via the `HKCU\Software\Microsoft\Windows\CurrentVersion\Run` registry key or a per-user scheduled task. None of these operations requires administrative privileges. Exfiltration may be performed via HTTPS requests to the Telegram Bot API, a Discord webhook, or SMTP to a free webmail account; none of these destinations is typically blocked by university egress filtering. The resulting installation, on a shared laboratory endpoint without application whitelisting, captures every keystroke of every subsequent user of the same Windows account until manually removed. On endpoints where students retain local administrator privileges, the installation can additionally be made persistent at machine scope and resistant to user-account-level removal.

2.6 Class F — Hardware keyloggers

Inline USB hardware keyloggers, marketed openly through online retailers at prices below USD 50, capture keystrokes at the hardware level, are invisible to software-based detection, and require physical retrieval by the attacker. They are excluded from the principal defensive scope of this proposal — no software-only remediation defeats them — but are noted for completeness and addressed procedurally in Section 3.6.

3. PROPOSED ARCHITECTURAL REMEDIATION

The remediation proposed in this section addresses Classes A through E using only software already licensed to NSU (Microsoft Windows 10/11, Microsoft Defender Antivirus) or available at zero license cost (Chrome Enterprise policies administered via Chrome Browser Cloud Management, Microsoft Sysmon, Wazuh). The total external software expenditure for the proposed deployment is zero.

The intervention follows the principle that user behaviour cannot be reliably modified through training alone (Section 1.1), and that the defensive response must therefore consist of architectural changes that remove the *opportunity* for the relevant user actions to result in credential exposure. Each subsection below addresses one or more of the attack classes from Section 2.

3.1 Chrome and Edge enterprise policy enforcement

The Chromium-based browsers expose, on Windows, a family of enterprise policies configurable through the Windows registry under `HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Google\Chrome` (for Chrome) and `HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Edge` (for Edge). The following policies, applied to all NSU-managed laboratory endpoints, eliminate the prerequisites for Classes A, B, and D:

Policy	Value	Effect
BrowserSignin	0	Disables browser sign-in. Users may use Gmail through a web tab but cannot sign the browser itself in

SyncDisabled	1	Belt-and-braces enforcement: prevents synchronisation even if sign-in occurs through an unintended p
RestrictSigninToPattern	.*@northsouth\.edu	If sign-in is required in any segment of the deployment, restricts it to the institutional domain.
PasswordManagerEnabled	0	Disables the Chrome and Edge built-in password manager. No credentials are written to the Login Dat
AutofillAddressEnabled	0	Disables address autofill.
AutofillCreditCardEnabled	0	Disables payment-method autofill.
BrowserGuestModeEnforced	1	Forces Guest Mode on laboratory endpoints; no profile data persists between sessions.
DeveloperToolsAvailability	2	Disables DevTools, preventing manual extraction of cookies and storage.
ExtensionInstallBlocklist	["*"]	Blocks all extensions by default.
ExtensionInstallAllowlist	(specific IDs)	Permits only IT-approved extensions.
BlockExternalExtensions	1	Blocks side-loaded extensions from outside the Web Store.

Deployment may be performed by any of three free mechanisms: Chrome Browser Cloud Management [21] (a no-cost cloud administration console for unlimited managed browsers), Group Policy via the official Chrome and Edge ADMX templates [22], or direct registry import on standalone endpoints. The Mozilla Firefox browser, should it be present on NSU endpoints, supports equivalent policies via the *policies.json* mechanism placed in `<install_dir>\distribution\`; analogous restrictions on sync, the password manager, and extension installation are advisable.

3.2 Windows Shared PC mode

Microsoft Windows 10 and 11 include a feature known as Shared PC mode [23], configurable through the SharedPC Configuration Service Provider, through Group Policy, or through Microsoft Intune. When enabled, Shared PC mode performs the following operations automatically:

- User profiles are deleted on sign-out (with configurable variants for deletion-on-disk-threshold or deletion-on-inactivity-threshold).
- The creation of new local accounts is disabled.
- Sleep mode is disabled, and forced sign-out is performed after a configurable inactivity period.
- “Remember me” affordances on the sign-in screen are removed.

For NSU laboratory endpoints, the recommended configuration is *EnableSharedPCMode* = *True*, *AccountModel* = *Domain-joined only*, *DeletionPolicy* = *0* (delete immediately at sign-out), and *SignInOnResume* = *True*. With this configuration, the persistence problem of Class A is eliminated by removing the persistent storage on which Classes A, B, and C depend. The Local Group Policy setting “Delete user profiles older than a specified number of days on system restart,” configured to one day, serves as a redundant safety net.

A known constraint of Shared PC mode is that locally created accounts existing prior to the activation of the feature are not automatically removed; an inventory and cleanup of pre-existing local accounts is required as part of the deployment.

3.3 Microsoft Defender Attack Surface Reduction rules

Microsoft Defender for Endpoint exposes a family of Attack Surface Reduction (ASR) rules [24], available on any Windows 10 or 11 endpoint with Defender enabled, that block specific classes of malicious behaviour at the kernel level. The rules relevant to the defence against Class E (native keyloggers) and to defence-in-depth against malware capable of executing Class C in an automated fashion include:

Rule GUID (abbreviated)	Description
9e6c4e1f … 9e4b2	Block credential stealing from LSASS. Default-on as of 2024; verify per endpoint.
d4f940ab … 0688a	Block all Office applications from creating child processes.
3b576869 … 9e899	Block Office applications from creating executable content.
d3e037e1 … 7596d	Block JavaScript or VBScript from launching downloaded executable content.
5beb7efe … 04cc	Block execution of potentially obfuscated scripts.
7674ba52 … 9a2c	Block Adobe Reader from creating child processes.
26190899 … e869	Block Office communication app (Outlook) from creating child processes.
e6db77e5 … 1e5b	Block persistence through WMI event subscription.
b2b3f03d … 9ba4	Block untrusted USB processes.
01443614 … bfc25	Block executable files from running unless they meet prevalence, age, or trusted-list criteria.

The recommended deployment sequence is to enable each rule in Audit mode for a period of one to two weeks, identify legitimate software that is incorrectly flagged (typically a small number of patch-management and software-deployment utilities, for which Microsoft maintains documented guidance), establish exclusions, and then transition to Block mode. The LSASS rule does not support Warn mode and must be deployed as either Audit or Block.

3.4 Defence-in-depth: standard user accounts, AppLocker, PowerShell Constrained Language Mode

Several additional Windows-native controls reduce the attack surface available to Class E:

- **Standard user accounts.** Student lab accounts should not be members of the local Administrators group. A separate administrative account, available only to IT staff, should be used for maintenance.
- **AppLocker** [25], available on Windows Pro, Enterprise, and Education editions at no additional cost, permits whitelist-based control of executable files, scripts, and installer packages. The minimum advisable configuration denies execution from user-writable paths (*C:\Users*\AppData*, *C:\Users*\Downloads*) for standard users and restricts interpreters (*pythonw.exe*, *wscript.exe*, *cscript.exe*, *mshta.exe*, *powershell.exe*) to executions from *C:\Program Files* or to explicitly approved scripts.
- **PowerShell Constrained Language Mode** [26], enabled through AppLocker policy or the `__PSLockdownPolicy` environment variable, restricts PowerShell on standard-user contexts to a subset of the language that disables most reflection-based attacks while preserving administrative scripting capability.
- **USB removable-storage restrictions.** Group Policy under Computer Configuration → Administrative Templates → System → Removable Storage Access permits the denial of read or execute access to removable media for standard users, mitigating the introduction of malicious tooling through USB drives.

3.5 Detection: Sysmon and Wazuh

The preceding measures are preventive. To detect attempts to bypass these controls and to provide forensic visibility, Microsoft Sysmon [27] and the open-source Wazuh security platform [28] should be deployed in tandem. Sysmon, installed as a Windows service on each endpoint, produces detailed event-log telemetry; the Wazuh agent forwards these events to a Wazuh manager server, which applies decoder and detection rules. Wazuh maintains documented guidance for detecting keylogger behaviour [29], process injection [30], and Windows persistence techniques [31].

The custom Wazuh rule set proposed for the present deployment includes alerts on:

- Sysmon Event ID 11 (FileCreate) with paths matching **\Login Data* written outside **\Google\Chrome\User Data** — indicative of the credential database being copied for offline extraction.
- Sysmon Event ID 10 (ProcessAccess) opening *lsass.exe* with *GrantedAccess* values associated with memory-read operations (0x1010, 0x1410) — indicative of Mimikatz, LaZagne, or equivalent credential-dumping tools.
- Sysmon Event ID 1 (ProcessCreate) on *pythonw.exe*, *wscript.exe*, *mshta.exe*, and *powershell.exe* with *-WindowStyle Hidden*, particularly when spawned by non-interactive parent processes.
- Sysmon Event ID 12 and 13 (RegistryEvent) writes to *HKCU\Software\Microsoft\Windows\CurrentVersion\Run* and the corresponding HKLM key.
- Sysmon Event ID 3 (NetworkConnect) outbound HTTPS connections to *api.telegram.org*, *discord.com/api/webhooks*, and known anonymous file-upload destinations from non-browser processes.
- Sysmon Event ID 25 (ProcessTampering).

Wazuh's Active Response module permits the automated termination of offending processes and the quarantine of associated binaries upon rule match. The complete stack — Sysmon, Wazuh manager, Wazuh agents, the rule set — is free and open source.

3.6 Procedural controls and hardware keyloggers

Class F (hardware keyloggers) is not addressable by software-only means. Procedural controls include the application of tamper-evident stickers to USB ports on high-risk endpoints (registrar, finance, examination-control office machines), routine physical inspection by laboratory attendants, and the use of PS/2 keyboards where inline keyloggers are more conspicuous. Group-Policy-based USB device identifier whitelisting, available through Microsoft Defender device control, provides partial mitigation against the introduction of unknown USB devices in general.

3.7 Recommendation regarding institutional password management

The Chrome and Edge built-in password managers are unsuitable as institutional password storage on shared endpoints, for the reasons developed in Sections 2.1 through 2.3. For staff use on personal or institutionally-issued (non-shared) endpoints, the open-source password manager Bitwarden [32] is recommended. Bitwarden encrypts saved credentials under a user-chosen master password independent of the operating-system user account, locks automatically on browser closure, and requires re-authentication for export operations. The Bitwarden Teams Starter plan is available at no cost for up to ten users; for institutional-scale deployment, the self-hosted alternative Vaultwarden [33], distributed as a single Docker container, supports unlimited users at zero license cost.

4. EVALUATION PLAN: A MEASUREMENT AND INTERVENTION STUDY

The remediation proposed in Section 3 is intended to be both an operational improvement to NSU's security posture and the basis of a peer-reviewable empirical contribution. This section describes the measurement and intervention study design.

4.1 Research questions

RQ1. What is the present-day prevalence of inter-session credential exposure on NSU laboratory endpoints? Specifically, on a representative sample of NSU-managed shared laboratory computers, in what proportion (a) is the Chrome built-in password manager enabled, (b) does Chrome Sync remain enabled by default, (c) does the local profile directory persist beyond user session termination, and (d) is the Login Data database readable and decryptable by a standard-user process operating under the shared Windows account?

RQ2. What is the effect of the proposed architectural remediation on the simulated-attacker credential extraction success rate, measured pre-intervention and post-intervention on matched laboratory endpoints?

RQ3. What unintended user-behavioural consequences result from the remediation? In particular, do users compensate by installing unsupported browsers, by storing credentials in alternative locations (cloud documents, personal devices), or by exhibiting increased session-sharing behaviour?

4.2 Study design

The study adopts a controlled deployment design with one intervention site (Laboratory A) and one control site (Laboratory B) matched on size, course usage, and student demographic, both within NSU. Three phases are proposed:

Phase I — Baseline measurement (weeks 1–6). (i) A PowerShell-based audit script enumerates the policy state of each endpoint in both laboratories, recording configured values for the policies enumerated in Section 3.1, the activation state of Shared PC mode, the enablement state of each ASR rule, and the presence or absence of the Sysmon service. No user data is read. (ii) On a sample of endpoints, with the cooperation of the IT Office and using only research-team-owned seeded test accounts, the simulated-attacker extraction procedure is exercised and pass/fail outcomes recorded. No actual student credential is read, stored, or transmitted at any phase of the study. (iii) An anonymous online survey, available in Bangla and English, is distributed to lab users (target N = 500) covering self-reported behaviour: frequency of Chrome sign-in on lab endpoints, sync enablement, session-termination practice, and previous experience of finding a prior user's profile signed in.

Phase II — Intervention (weeks 7–18). The architectural remediation of Section 3 is deployed to Laboratory A. Laboratory B remains in its baseline configuration. The audit script is rerun to verify deployment.

Phase III — Post-intervention measurement (weeks 19–22). The simulated-attacker extraction procedure is rerun on both laboratories. The survey is redistributed. A subsample of users participates in semi-structured interviews regarding adaptation behaviours.

4.3 Analysis

The primary outcome variable is the binary per-endpoint pass/fail outcome of the simulated-attacker extraction procedure. The principal analyses are (i) a within-Laboratory-A pre-versus-post comparison and (ii) a between-laboratory post-intervention comparison, both via mixed-effects logistic regression with laboratory as a random effect.

Secondary outcomes include the proportion of endpoints exhibiting non-empty Login Data databases under standard-user inspection (with opt-in consent, with reporting at the level of database row count only and never the contents), the self-reported sync-usage rate in the survey, and the rate of incidents in which a user observed a prior session signed in. Pre-registration of the analysis plan on the Open Science Framework is intended.

4.4 Ethical considerations

The study design is contingent on review and approval by the appropriate NSU ethics committee. The following commitments are made unconditionally:

- At no phase of the study does the research team read, store, or transmit any actual student or staff credential. The simulated-attacker procedure exclusively uses seeded test accounts owned by the research team.
- Where database-level inspection of real endpoints is performed, the operation is restricted to counting the number of entries (an integer), with explicit opt-in consent from the lab user at the time of inspection.
- All deployment work is performed under the supervision and with the consent of the NSU Information Technology Office. The research team does not unilaterally modify the configuration of NSU endpoints.
- Lab-level policy auditing is announced through signage in the affected laboratories prior to data collection.
- The study design and protocol are pre-registered prior to the commencement of data collection.

The Bangladesh Cyber Security Ordinance 2025 [11] establishes penalties for unauthorised access to information systems. The present proposal is, by design, an authorised activity undertaken with the cooperation of the institution that owns the affected systems. No measurement or intervention activity is undertaken in the absence of written authorisation from the NSU IT Office, and the research team's actions are at all times in scope of that authorisation.

4.5 Anticipated publication venues

The study, if completed as designed, produces a deployment-and-measurement contribution of a type historically published in the following venues, in approximate order of fit:

- The Symposium on Usable Privacy and Security (SOUPS), co-located with the USENIX Security Symposium.
- USENIX Enigma, which accepts short, practice-oriented case studies of security deployments.
- The Annual Computer Security Applications Conference (ACSAC) Case Studies track.

- The Oxford University Press *Journal of Cybersecurity*.
- IEEE Access and Elsevier *Computers & Security*, providing open-access publication at faster turnaround.

The novelty contribution claimed for this work is twofold. First, the inter-session credential exposure problem on shared university endpoints, while well known in the practitioner literature, has received remarkably little measurement attention in the peer-reviewed academic literature, particularly in institutional contexts outside North America and Western Europe. Second, the proposed architectural remediation, although composed entirely of documented vendor features and open-source tools, has, to the author's knowledge, not been the subject of a controlled before-and-after measurement study at a South Asian university.

5. DISCUSSION

5.1 Limitations of the proposed remediation

The remediation of Section 3 does not address the full spectrum of credential-theft attack vectors against NSU. It does not, in itself, defend against (i) phishing-delivered credential capture on personal student devices outside the NSU-managed estate, (ii) infostealer malware infections on personal devices that subsequently authenticate to NSU services, (iii) password reuse across institutional and personal services, (iv) the compromise of personal accounts of users with elevated administrative privileges, or (v) hardware-level attacks (Class F, Section 2.6). The remediation is intended to be complementary to the inbox-defence measures (DMARC enforcement, mandatory two-step verification on staff accounts, FIDO2 hardware keys for administrative accounts, Gmail enhanced pre-delivery scanning) addressed in a separate proposal document.

The deployment introduces user-experience trade-offs. Shared PC mode prevents users from “leaving a session open” and resuming it later, a workflow that some students rely on. Forced extension allowlisting prevents users from installing extensions of their own choice on laboratory endpoints; this is intended and acceptable on shared resources but will require clear communication. Disabling the browser built-in password manager removes a convenience feature, which is mitigated by the recommendation of Bitwarden for personal use.

The Application-Bound Encryption feature introduced by Google in Chrome 127 [16] reduces but does not eliminate the offline extraction problem of Class C. The relevant infostealer families bypass the protection, as documented in the practitioner literature; further, the protection applies primarily to cookies rather than to saved passwords. The remediation of Section 3 should be regarded as defence-in-depth around App-Bound Encryption, not as a substitute for it.

5.2 Assumptions requiring verification

The present proposal is written under several assumptions about NSU's current technical state that require verification during the Phase I audit. These are: (i) the user-account population is approximately twenty-five thousand; (ii) the institution operates Google Workspace for Education on *@northsouth.edu*; (iii) laboratory endpoints predominantly run Windows 10 or 11 with Microsoft Defender as the primary anti-malware product; (iv) Active Directory or a comparable directory service is available for Group Policy deployment; (v) the Chrome and Edge browsers are the principal browsers on managed endpoints. Each assumption may prove incorrect on inspection, in which case the proposed deployment must be adjusted; none, however, materially alters the substance of the proposal.

5.3 Relationship to the broader threat landscape

The infostealer ecosystem characterised in Section 1.1 and the Snowflake breach pattern [2] of 2024 represent the most consequential credential-theft attack pattern of the contemporary period. The Snowflake compromises proceeded not from the exploitation of any defect in the cloud platform itself but from the harvesting of cached browser credentials on the personal and contractor devices of users authorised to access that platform. The shared university endpoint, under default browser configuration, presents the same data-flow pattern at smaller scale: locally cached credentials, harvestable by a process operating in the user's context, with the credentials proceeding to be useful against high-value services. The proposed remediation interrupts this data flow at NSU.

5.4 Institutional and academic benefits

The completion of the study described in Section 4, with publication at one of the venues identified in Section 4.5, would constitute a peer-reviewed first-author research contribution by the proposing author, in a domain characterised by relative scarcity of published work. The NSU institutional name on such a publication is of independent value. The open-source release of the deployment artefacts — Group Policy templates, ASR configuration scripts, Wazuh rule sets, the audit script — is intended to be of immediate use to other Bangladeshi and South Asian universities operating with comparable resource constraints.

6. REQUEST AND CONCLUSION

This proposal requests authorisation from the appropriate NSU administrative office for a thirty-day pilot deployment of the architectural remediation described in Section 3, on a single laboratory of approximately thirty endpoints, with the cooperation of the NSU Information Technology Office and the supervision of a designated faculty member from the Department of Computer Science and Engineering. Specific permissions requested are:

- (1) Execution of a read-only policy-state audit script on the endpoints of the designated laboratory and one matched control laboratory.

- (2) Deployment of the Chrome and Edge enterprise policies of Section 3.1 via Group Policy or Chrome Browser Cloud Management.
- (3) Activation of Windows Shared PC mode (Section 3.2) with immediate-deletion-on-sign-out on the designated laboratory.
- (4) Enablement of the Defender Attack Surface Reduction rules of Section 3.3, initially in Audit mode and subsequently in Block mode after one to two weeks of exception identification.
- (5) Deployment of Sysmon and Wazuh agents (Section 3.5) in audit mode on the designated laboratory and the matched control.
- (6) Subject to NSU ethics committee approval, distribution of an anonymous user survey and conduct of opt-in inspection of Login Data row counts on a sample of endpoints, with the strict ethical commitments enumerated in Section 4.4.

The external software cost of the proposed deployment is zero. The hardware required for the Wazuh manager, the Sysmon log ingestion, and the audit-script execution can be satisfied by a single existing or repurposed laboratory server, with the Wazuh single-node all-in-one installer accommodating the scale of one laboratory.

The proposing author requests that the pilot be conducted under a written memorandum of understanding specifying the deliverables (audit report, intervention report, draft research paper), the timeline (nine months from authorisation), the assignment of authorship on any resulting publication (first authorship to the proposing author, co-authorship to the faculty supervisor and the IT Office's designated representative), and the open-source licensing of all deployment artefacts.

The shared university endpoint, in its default configuration, leaks the credentials of one user to the next. The remediation is documented, free, and within the operational competence of the NSU Information Technology Office. The present proposal asks only for the authorisation to deploy it, the cooperation to measure its effect, and the academic supervision to convert the result into a peer-reviewed contribution.

REFERENCES

- [1] Verizon Business, *2025 Data Breach Investigations Report*, 2025.
- [2] Mandiant, “UNC5537 Targets Snowflake Customer Instances for Data Theft and Extortion,” Jun. 10, 2024.
- [3] IBM Security, *X-Force Threat Intelligence Index 2025*, 2025.
- [4] M. P. Steves, K. K. Greene, and M. F. Theofanos, “Categorizing human phishing difficulty: a Phish Scale,” *Journal of Cybersecurity*, vol. 6, no. 1, 2020, doi: 10.1093/cybsec/tyaa009.
- [5] D. Lain, K. Kostianen, and S. ■apkun, “Phishing in Organizations: Findings from a Large-Scale and Long-Term Study,” in *Proc. IEEE Symposium on Security and Privacy*, 2022, pp. 842–859, doi: 10.1109/SP46214.2022.9833766.
- [6] A. Rozema and S. Davis, “Anti-Phishing Training (Still) Does Not Work: A Large-Scale Reproduction of Phishing Training Inefficacy Grounded in the NIST Phish Scale,” arXiv:2506.19899, 2025.
- [7] D. Lain et al., “Content, Nudges and Incentives: A Study on the Effectiveness and Perception of Embedded Phishing Training,” in *Proc. ACM Conference on Computer and Communications Security*, 2024, doi: 10.1145/3658644.3690348.
- [8] Google, “Chrome Enterprise Policy List & Management,” 2025. Available: <https://chromeenterprise.google/policies/>
- [9] Microsoft, “DPAPI Secrets — Windows authentication and credential storage,” Microsoft Learn, 2025.
- [10] *The Daily Star*, “Hackers breach NSU registrar's email to expose security issues,” 2022.
- [11] Government of the People's Republic of Bangladesh, *The Cyber Security Ordinance 2025*, gazetted 21 May 2025.
- [12] Government of the People's Republic of Bangladesh, *The Personal Data Protection Ordinance 2025*, promulgated 6 November 2025.
- [13] NirSoft, “ChromePass — password recovery tool for Google Chrome web browser.”
- [14] A. Zapata, “LaZagne: credentials recovery project,” GitHub: AlessandroZ/LaZagne.
- [15] moonD4rk, “HackBrowserData: decrypt passwords, bookmarks, history, cookies from browsers,” GitHub: moonD4rk/HackBrowserData.
- [16] Elastic Security Labs, “Katz and Mouse Game: MaaS Infostealers Adapt to Patched Chrome Defenses,” Oct. 28, 2024.
- [17] Google, “Manifest V3 — Chrome for Developers,” 2025.
- [18] Cyberhaven, “Cyberhaven's Chrome extension security incident and what we're doing about it,” Dec. 26, 2024.
- [19] Carnegie Mellon University Information Security Office, “Google Chrome Extensions Vulnerabilities,” 2025.
- [20] A. Sharma, “A Study on Malicious Browser Extensions in 2025,” arXiv:2503.04292, 2025.
- [21] Google, “Chrome Browser Cloud Management.”
- [22] Google, “Set Chrome policies for users or browsers,” Chrome Enterprise and Education Help.
- [23] Microsoft, “Manage multi-user and guest Windows devices,” Microsoft Learn.
- [24] Microsoft, “Attack Surface Reduction rules reference,” Microsoft Defender for Endpoint documentation.
- [25] Microsoft, “AppLocker overview,” Microsoft Learn.
- [26] L. Holmes, “PowerShell Constrained Language Mode,” Microsoft DevBlogs, 2017.
- [27] M. Russinovich and T. Garnier, “Sysmon (System Monitor),” Microsoft Sysinternals.
- [28] Wazuh Inc., “Wazuh — Open Source XDR. Open Source SIEM.”
- [29] Wazuh Inc., “Snake keylogger detection with Wazuh,” 2024.
- [30] Wazuh Inc., “Detecting process injection attacks with Wazuh,” 2024.
- [31] Wazuh Inc., “Detecting Windows persistence techniques with Wazuh,” 2025.

[32] Bitwarden Inc., “Bitwarden — open source password manager.”

[33] dani-garcia, “Vaultwarden: alternative implementation of the Bitwarden server API,” GitHub: [dani-garcia/vaultwarden](https://github.com/dani-garcia/vaultwarden).